
第 1 章 绪论

1、填空题

(1) 信息安全包含系统安全、数据安全、内容安全和行为安全等四个层次。

(2) 信息系统的脆弱性主要包括：电磁泄漏、芯片的脆弱性、操作系统的安全漏洞、数据库系统的安全漏洞、通信协议的安全漏洞和移动存储介质的安全漏洞。

(3) 人为安全威胁的来源包括：物理攻击、网络攻击、恶意代码和安全管理。

2、选择题（单选和多选）

(1) 2008 年，XXX 国利用 BGP（Border Gateway Protocol 边界网关协议）劫持，破坏了格鲁吉亚的互联网，瘫痪了所有政府的基础设施。这种攻击行为属于（A）
A.网络攻击；B.物理攻击；C.病毒攻击；D.安全管理

(2) 1982 年，由工业控制软件内嵌的病毒引发泛西伯利亚天然气管道发生大爆炸。这种攻击行为属于（C）
A.网络攻击；B.物理攻击；C.恶意代码攻击；D.安全管理

(3) 以下描述是正确的有（D）
A.安全风险是“绝对的”，但我们可以完全消除；
B.信息系统的安全风险一定会使系统遭受安全损失；
C.安全风险虽不能完全消除，但可以降低对系统的危害；
D.安全威胁一定会造成安全损失，因此我们必须严防安全威胁。

3、问答题

(1) 如果信息系统无任何脆弱性，是否就不存在安全风险呢？分析举例。

答：即使信息系统无任何脆弱性，也仍然存在安全风险，因为安全风险是绝对的，且和人的行为密切相关。如使用者对信息系统内容的恶意泄露。

(2) 信息系统的脆弱性和安全威胁分别体现在哪些方面？简要阐述。

答：脆弱性：电磁泄漏、芯片的脆弱性、操作系统的安全漏洞、数据库系统的安全漏洞、通信协议的安全漏洞、移动存储介质的安全漏洞

(3) 根据标准 GA/T 708-2007, 信息系统的基本安全属性包含哪些? 除此之外, 你认为信息系统还需要有哪些安全需求? 举例说明。

答: 保密性、完整性、可用性。这三个基本安全需求已经比较全面了, 我觉得信息系统还需要具有可安全移植性, 同一个信息安全系统在不同的网络环境中, 不因协议等因素, 都能保持完整安全可用

(4) 如何理解: 安全管理的最终目的是“使安全风险降低到用户和决策者都可以接受的程度”?

答: 首先, 安全风险的存在是绝对的, 不可能被完全消除, 只能根据需求降低; 其次, 对于用户来说, 安全管理的规则要为便利性服务, 过度追求“零风险”会影响可用性, 对于决策者来说, 需要考虑安全风险管理产生的成本和生产使用效率的投入产出比, 过度追求“零风险”会使成本也趋于无穷大